

Bilgi Toplama Yöntemleri

Siber Saldırı ve Savunma Yöntemleri - Hafta 6



Siber Saldırı ve Savunma Yöntemleri

Bu sunum, siber güvenlik alanında kritik öneme sahip olan Bilgi Toplama Tekniklerini incelemektedir.

Bilgi toplama aşaması, siber saldırıların temelini oluşturur ve savunma mekanizmalarının anlaşılması için zorunludur.

Konularımız, sızma testlerinde kullanılan temel araçları ve pasif/aktif keşif yöntemlerini kapsamaktadır.



Eğitim Ortamı Hazırlığı

Pratik siber güvenlik uygulamaları genellikle izole ve güvenli bir ortamda gerçekleştirilmelidir.

Bu amaçla, VirtualBox gibi bir sanallaştırma platformu kullanılarak Kali Linux işletim sisteminin kurulması gerekmektedir.

Kali Linux, sızma testleri ve güvenlik denetimleri için önceden yüklenmiş yüzlerce araç içeren Debian tabanlı bir dağıtımdır.



VirtualBox İndirme Adımları

VirtualBox, Kali Linux kurulumu için en çok tercih edilen sanallaştırma yazılımlarından biridir.

Yazılımın en güncel ve stabil sürümünü indirmek için resmi web sayfası kullanılmalıdır.

İndirme adresi: <https://www.virtualbox.org/wiki/Downloads>

Kali Linux Sanal Makine İmajı İndirme

VirtualBox üzerine kurulacak Kali Linux'un 'virtual machines' (sanal makineler) için önceden hazırlanmış imajları tercih edilir.

Bu imajlar, kurulum sürecini basitleştirir ve performansı optimize eder.

İndirme adresi: <https://www.kali.org/get-kali/#kali-virtual-machines>



VirtualBox Yeni Makine Oluřturma

VirtualBox bařlatıldıktan sonra 'Yeni' seeneęi (Makine -> Yeni) seilerek kurulum sihirbazı bařlatılır.
Sanal makine adı girilir ve temel sistem tipi belirlenir.
'Type' (Tip) olarak Linux seeneęi ayarlanmalıdır.

Sürüm ve Mimari Seçimi

Kali Linux'un genellikle x64 masaüstü imajı kullanıldığı için, 'Sürüm' (Version) bölümünde Debian (64-bit) seçeneği belirlenmelidir. Bu seçim, sanal makinenin doğru mimari ayarlarını kullanmasını sağlar.



Bellek (RAM) Boyutunun Tanımlanması

RAM miktarı, sanal makinenin aynı anda çalıştırabileceği uygulama sayısını ve performansını doğrudan etkiler.

Kali'deki bazı araçlar yüksek kaynak gereksinimi duyabilir.

Genel sanal makine kurulumları için 2048 MB (2 GB) RAM miktarı başlangıç olarak seçilmektedir.

Yüksek performanslı cihazlarda bu miktar artırılabilir.



Sabit Disk Oluřturma ve Tür Seçimi

Sihirbazın 'Sabit disk' ekranında yeni bir sanal disk oluşturulması gerekir. 'Sabit disk dosya türü' olarak genellikle varsayılan seçenek olan VDI (VirtualBox Disk Image) seçeneęi kullanılır.



Depolama Tipi Seçimi

'Fiziksel sabit diskte depolama' seçeneği için Dinamik olarak tahsis edilen (Dynamically allocated) varsayılan seçeneğin kullanılması önerilir. Dinamik tahsis, diskin fiziksel boyutu ihtiyaca göre büyümesini sağlar, bu da depolama alanından tasarruf edilmesine yardımcı olur.

Sanal Disk Boyutu Belirleme

'Dosya konumu ve boyutu' ekranında sanal hard diskin ne kadar büyük olacağı tanımlanır.
VM'ler için genellikle 80,00 GB gibi yeterli bir alan kullanılması tavsiye edilir.



Gelişmiş Ayarlar: Paylaşılan Pano ve Sürükle Bırak

VM oluşturulduktan sonra, ek özelleştirmeler için 'Ayarlar' menüsüne girilir. 'Genel' -> 'Gelişmiş' bölümünde, 'Paylaşılan Pano' ve 'Sürükle ve Bırak' özelliklerinin 'Çift yönlü' (Bidirectional) olarak ayarlanması, ana makine ile VM arasında veri transferini kolaylaştırır.

Sistem Ayarları: Önyükleme Sırası

'Sistem' -> 'Anakart' bölümünde 'Önyükleme Sırası' değiştirilmelidir.
Sabit Diskin üstte ve Optik'in ikinci sırada olması sağlanır.
Geriye kalan tüm önyükleme cihazları (örneğin Disket) devre dışı bırakılır.



İşlemci Ayarları

'Sistem' -> 'İşlemci' kısmında sanal makineye ayrılan 'İşlemci(ler)' sayısı artırılmalıdır. Genellikle 2 işlemci seçeneği yeterlidir. Aynı zamanda PAE/NX (Genişletilmiş Özellikler) etkinleştirilmelidir. Bu, bazı 64-bit sistemlerin sanallaştırılması için kritik bir ayardır.



Görüntü Ayarları

'Ekran' -> 'Ekran' bölümünde 'Video Belleği' miktarı genellikle 128 MB olarak ayarlanır.

Ayrıca, kullanıcıların sorunlara neden olduğunu bildirmesi nedeniyle 'Hızlandırılmış 3D grafiklerin' kesinlikle devre dışı bırakıldığından emin olunmalıdır.

Sanal Makine Başlatma ve Varsayılan Kimlik Bilgileri

Tüm ayarlar tamamlandıktan sonra 'Başlat'a basılarak sanal makine çalıştırılabilir.

Canlı Önyükleme (Live Boot) veya önceden oluşturulmuş görüntü (Sanal Makineler) kullanılırken varsayılan işletim sistemi kimlik bilgileri şunlardır:

Kullanıcı: kali

Şifre: kali

AMD64 ve i386 görsellerinin standart kurulumunda ise sizden yeni bir kullanıcı hesabı oluşturulması istenecektir.



Bilgi Toplama Teknikleri - I

Siber saldırı veya sızma testlerinin ilk adımı, hedef hakkında olabildiğince çok veri toplamaktır.

Pasif bilgi toplama yöntemlerinde, bilgi alınmak istenen hedef ağ veya sistem ile doğrudan iletişime geçilmez.

Bu, hedef sistemde log kaydı oluşmamasını ve iz bırakılmamasını sağlar.



Pasif Bilgi Toplamanın Özellikleri

Pasif bilgi toplama, genellikle yüzeysel ancak değerli başlangıç bilgileri elde etmeyi amaçlar.

Bu yöntemde ağ veya sistem hakkında bilgi edinmek için sadece internet kaynaklarından (arama motorları, genel kayıtlar, Whois verileri vb.) yararlanılır.

Pasif bilgi toplama yöntemleri şunlardır:

1. IP adresleri üzerinden bilgi toplama
2. Domainler üzerinden bilgi toplama
3. Web sayfalarından bilgi toplama

IP Adresleri Üzerinden Bilgi Toplama

IP adreslerinin dağıtımında yetkili olan tek merkez, kâr amacı gütmeyen ICANN'dir (İnternet Tahsisli Sayılar ve İsimler Kurumu).

ICANN'ın sorumlulukları şunlardır:

1. IP adres alanı tahsisi ve protokol ataması
2. Ülke kodu ve internet alan adı yönetimi
3. İnternet ana servis sağlayıcı idaresinin koordinasyonu



Whois Sorgusu

Whois, sorgulanan IP adresi veya alan adı ile ilgili bilgilere ulaşmayı sağlayan bir protokoldür.

Whois sorgusu ile yasal çerçevede listelenen bilgiler:

1. Alan adı sahibi kişiye veya kuruma ait iletişim bilgileri (telefon, adres, e-posta)
2. Alan adı ile ilgili teknik bilgiler (domain sunucu, IP aralığı)

Whois Gizleme Mekanizmaları

Alan adının veya IP adresinin sahibi, kişisel bilgilerinin Whois sorgusu sırasında listelenmesini istemeyebilir.

Bunun için Whois gizleme servisinin aktif edilmesi gerekir.

ICANN, bu servis sayesinde bilgileri gizler ve sorgulama yapanların bu detayları görmesini engeller, böylece gizlilik sağlanır.



SHODAN CLI Komutları

SHODAN CLI (Command Line Interface) komutları, açık kaynak istihbarat gerçekleştirmek için kullanılır.

Bu komutlar, hedefin kolay ve pasif bir şekilde analiz edilmesini sağlar. Shodan arama motoru ile hedef sistemin altyapılarına erişilebilmesi ve sistem hakkında ayrıntılı bilgi toplanabilmesi için terminal üzerinden shodan komutları uygulanır.

RIPE NCC Sorgulama

RIPE NCC, Avrupa, Ortadoğu ve Orta Asya'nın bazı bölgelerine IP adresi tahsisinden sorumlu, kâr amacı gütmeyen bir kuruluştur. Bu bölgelerde yer alan IP adreslerine ilişkin pasif bilgi sorgulaması yapmak için resmi web adresi kullanılır: <https://www.ripe.net> ilgili web sayfasında bilgi alınmak istenen IP adresi yazılarak sorgulama yapılır ve RIPE NCC verilerine ulaşılır.



Bing Arama Motoru (IP Operatörü)

Bing arama motoru, verilen bir IP adresinde yer alan web siteleri hakkında bilgi toplamak için kullanılabilir.

Bu amaçla özel bir operatör kullanılır:

Sorgulama, Bing arama çubuğuna 'ip: ip_adresi' şeklinde yapılarak gerçekleştirilir.



IP Location Aracı

IP Location, hedef IP adresini beş farklı servis üzerinde sorgulayarak coğrafi konum tespiti sağlar.

Coğrafi konum tespiti yapılmak istenen IP adresi arama çubuğuna yazılarak sorgulanır.

Not: IP Location ile coğrafi konum sorgulama sonuçları, servis sağlayıcılar arasında farklılık gösterebilir.



Domainler Üzerinden Bilgi Toplama

Her web sitesinin fiziksel olarak bir IP adresi bulunur.
Ancak IP adreslerinin akılda tutulması zor olduğu için web sitelerine erişimde genellikle alan adı (domain) kullanılır.
Alan adı, IP adresinin kelimelerle ifade edilen hâlidir.

DNS Çözümleme Süreci

Kullanıcı web tarayıcısının adres çubuğuna bir alan adı yazdığında (örneğin: eba.gov.tr), DNS (Domain Name System) bu alan adının karşılık geldiği IP adresini çözümler.

Daha sonra bu IP adresindeki sunucuya erişim sağlanır.

Alan adının aktif olup olmadığına ilişkin bilgi toplamak için özel domain sorgulama internet siteleri kullanılır.



NS.TOOLS Aracı

NS.TOOLS, bir alan adının aktif mi yoksa pasif mi olduğunu öğrenmek için ping işlemi uygulayan bir araçtır.

Bu araç kullanılarak domain ile ilgili ek bilgiler de toplanır:

1. DNS kayıtları
2. IP adresleri
3. E-mail sunucusu bilgileri
4. Web bilgileri

TheHarvester Keşif Aracı (Giriş)

TheHarvester, internet üzerinden kişilerin ve kurumların bıraktığı 'ayak izini' anlamak için kullanılan bir keşif aracıdır. Temel amacı, hedef alan adının e-posta adreslerini ve alt alan adlarını tespit etmektir. Bu araç, Kali Linux işletim sistemi üzerinde önceden yüklü olarak gelir.

TheHarvester Yardım Sayfası ve Temel Parametreler

TheHarvester'in kullanımı, komut satırında -h parametresi ile yardım sayfası açılarak detaylıca incelenebilir.

En temel komut parametreleri şunlardır:

- d parametresi: Hedef alan adını belirtir.
- l parametresi: Arama yapılacak sonuç sayısını belirtir. (Varsayılan 500)
- b parametresi: Arama yapılacak arama motoru listesini belirtir.

TheHarvester Uygulaması: Hedef Belirleme

Uygulama Adımı 1: Bilgi toplamak istenen hedef alan adı belirlenir.

Uygulama Adımı 2: Hedef e-posta adreslerini ve alt alan adlarını tespit etmek için theHarvester komutu kullanılır.

Komut, -d parametresi ile hedefi, -b parametresi ile arama kaynaklarını belirtir.



TheHarvester Arama Motorları

-b parametresi ile arama yapılacak kaynak arama motorları belirtilir. Tüm popüler arama motorlarını kullanmak için 'all' kelimesi kullanılabilir. Hedef domain hakkında bilgi toplamak için popüler arama motorları şunlardır: google, bing, baidu, duckduckgo, linkedin, yahoo, netcraft, twitter, urlscan. Eğer hedef yazılım sektörü ise github da eklenebilir.



TheHarvester Detaylı Çıktı Parametreleri

- l parametresi: Arama yapılacak sonuç sayısını belirtir (Varsayılan 500).
 - S parametresi: Aramanın başlayacağı değeri belirtir (Varsayılan 0).
 - f parametresi: Arama sonuçlarının JSON ve XML formatında kaydedileceği dosya adını belirtir.
- Bu dosya çıktıları, toplanan bilgilerin daha sonra incelenmesi için kritik öneme sahiptir.

TheHarvester Özel Parametreler

TheHarvester aracının diğer önemli parametreleri ve işlevleri şunlardır:

- s parametresi: Shodan arama motoru üzerinden bilgi toplama sağlar.
- g parametresi: Google Dork kullanılarak özel bilgi elde edilmesini sağlar.
- p parametresi: Hedef alan adı üzerinde port taraması yapılmasını sağlar.

Sublist3r Aracı

Sublist3r, hedef alan adının alt alan adlarını (subdomains) arama motorlarını kullanarak araştıran ve sonuçları listeleyen bir araçtır.

Python diliyle yazılmış olup kullanımı kolaydır.

Not: Sublist3r aracı, Kali Linux içinde yüklü olarak gelmez ve sonradan kurulması gerekir.

-d parametresi ile alt alan adları tespit edilmek istenen hedef domain belirtilir.

Dnsenum Aracı

Dnsenum, hedef alan adına ait önemli bilgileri toplayan bir araçtır.

Topladığı bilgiler:

1. IP adresleri
2. Mail sunucuları
3. DNS sunucuları
4. Alt alan adları

Bu Perl diliyle yazılan araç, Kali Linux üzerinde yüklü olarak gelir ve 'dnsenum <alan adı>' şeklinde kullanılır.

Dnsenum: Zone Transfer ve Brute Force

Dnsenum, tespit edilen DNS sunucuları üzerinde hedef alan adına ait tüm kayıtları elde etmek için 'bölge transferi' (zone transfer) gerçekleştirmeye çalışır.

Alt alan adlarının tespiti için ayrıca '/usr/share/dnsenum/dns.txt' yolu üzerindeki dosya kullanılarak Brute Force (kaba kuvvet) saldırısı uygulanır. Ayrıca tespit edilen IP adresleri için C blok IP aralıkları listelenir.



LBD (Load Balancer Detector) Aracı

LBD, hedef alan adının DNS ve/veya HTTP yük dengeleme (Load Balancing) kullanıp kullanmadığını kontrol eden basit bir araçtır. Yük dengeleme tespiti, altyapı hakkında bilgi edinmek ve olası tek bir sunucuyu hedeflemek yerine yük dengeleyiciyi atlatma stratejileri geliştirmek için önemlidir. Kullanımı: 'lbd <alan adı>' şeklindedir.

Dnsrecon Aracı

Dnsrecon, hedef alan adına ait alt alan adlarını ve IP adreslerini arama motorları üzerinden tespit edebilen bir araçtır.

Python diliyle yazılmış olup Kali Linux üzerinde yüklü olarak gelir.

Dnsrecon, farklı arama tipleriyle (örneğin Bing, Yandex) sorgulama yapabilir.

-t parametresi: Hangi arama çeşidinin kullanılacağını belirtir (Örn: yandargümanı).

-d parametresi: Hedef alan adını belirtir.



Dnsrecon Uygulaması ve JSON Çıktısı

Dnsrecon komutu ile alt alan adları ve IP adresleri tespit edilebilir.
Uygulama adımı: Hedef alan adı belirlenir, -t parametresi ile arama çeşidi (örneğin bing) kullanılır, -d parametresi ile hedef belirtilir.
--json parametresi: Arama sonuçlarının JSON formatında kaydedileceği dosya adını belirtmek için kullanılır.



Maltego Keşif Aracı (Görselleştirme)

Maltego, hedef kurum ve kişi hakkında detaylı bilgi toplamak ve bu bilgileri görselleştirmek için kullanılır.

Bu araç, açık kaynaklardan elde edilen bilgileri görselleştirerek karmaşık bağlantıları anlamaya odaklanır ve veri madenciliği için uygundur.

Maltego'nun ücretli ve ücretsiz sürümleri mevcuttur ve Kali Linux üzerinde kurulu olarak gelir.



Maltego Kullanımı: Domain Nesnesi Ekleme

Maltego yazılımı, Kali Linux Uygulamalar menüsünden '01 - Information Gathering' seçilerek çalıştırılır.

Sol tarafta bulunan 'Entity Palette' penceresinin 'Infrastructure' bölümündeki 'Domain' nesnesi çalışma sayfasına sürüklenir.

Domain nesnesi üzerindeki alan adına çift tıklanarak bilgi toplanmak istenen hedef domain yazılır.

Maltego: Transform Çalıştırma

Domain nesnesi üzerinde sağ tuş yapılarak 'All Transforms' seçeneğinin yanındaki ok tuşuna tıklanır ve bilgi toplama işlemi başlatılır. Gelen pencerede 'Run' butonuna tıklanarak keşif işlemi tamamlanır. Bilgi toplama işlemi bittiğinde, toplanan bilgiler görsel bir şema şeklinde sunulur.

Web Sayfalarından Bilgi Toplama

Hedef sistemler, IP adresleri, alan adları, kullanıcılar ve kurumlar hakkında web sayfalarından detaylı bilgiler toplanabilir.

Bu yöntemde kullanılan kaynaklar:

1. DNS sorgulama yapan özel web sayfaları (Whois, IP Location)
2. Arama motorları (Bing, Google)
3. Arşiv siteleri (Archive.org)
4. Sosyal medya, bloglar, forumlar ve kariyer siteleri

Viewdns.info Araçları

Viewdns.info, birden çok siber güvenlik aracını tek bir web sitesinde sunar.

Bu araçla bulunabilecek bilgiler:

1. IP adresinin coğrafi konumu
2. MAC adresi ile ağ cihazının üreticisi
3. Bir sunucuda barınan web siteleri (Reverse IP Lookup)
4. Alt alan adları ve DNS kayıtları
5. Portların açık olma durumu

Sayfa aynı zamanda ping ve traceroute gibi araçları da kullanıma sunar.

Viewdns.info: HTTP Başlıkları (Get HTTP Headers)

HTTP başlıkları, hedef web sunucusunun türü, kullanılan yazılım versiyonları, çerez bilgileri ve bazı güvenlik ayarları hakkında bilgi verir.

Kullanım adımları:

1. HTTP başlığı bilgisi elde edilmek istenen hedef alan adı belirlenir.
2. Get HTTP Headers aracı ile alan adı sorgulanır.
3. Elde edilen HTTP başlığı incelenir (örneğin 'Server' bilgisi).

Archive.org (Wayback Machine)

Archive.org, 1996 yılından itibaren tüm web sitelerinin indekslerinin belli dönemlerde arşivlendiği bir web sayfasıdır.

Bu araç, yayından kaldırılan veya yayında olan web sitelerinin eski görünümlerine erişim sağlar.

Web sitelerinin yıllara, aylara ve günlere göre anlık görüntülerine (snapshots) ulaşılabilir.



Archive.org Kullanım Adımları

1. archive.org web sayfası açılır.
2. Arama çubuğuna bilgi toplanmak istenen web sitesinin adresi yazılır (örneğin meb.gov.tr).
3. Sorgulama sonucunda gelen takvimde, web sitesinin indekslenmiş tarihlerdeki anlık görüntülerine ulaşılır.
Belirli bir zaman damgalı (örneğin 10.12.2020 23:34:39) görüntü açılarak geçmişteki web sitesi içeriği incelenebilir.

SHODAN.io: Hackerların Arama Motoru

SHODAN (Sentient Hyper-Optimised Data Access Network), önsezileri güçlü en uygun veri erişim ağı anlamına gelir.

Saldırganlar, pasif keşif aşamasında hedef sistemlerin altyapılarına erişebilmek için bu web sitesini kullanır.

Shodan, dünya üzerinde internete bağlı olan farklı türlerdeki bilgi işlem sistemlerini tespit eder ve cihazlar hakkında bilgi toplar.



SHODAN ile Aranabilen Cihazlar

Kullanıcılar Shodan'ı kullanarak ülke ve şehir bazlı filtreleme yapabilir, tespit edilen sistem üzerindeki port ve servis bilgilerine, IP adreslerine ulaşabilir.

Aranabilecek sistemler:

1. IoT cihazları ve IP kameraları
2. Sunucular ve SCADA sistemleri
3. Nükleer santraller ve açık trafik ışığı sistemleri
4. Deniz uydu alıcıları (gemilerin konumları ve isimleri dahil).

SHODAN Uygulaması: Varsayılan Parola Sorgusu

Shodan arama motoru, zafiyetli sistemleri bulmak için kullanılır.
Örnek Uygulama: Varsayılan parola kullanan sistemlerin tespiti için arama çubuğuna 'default password' yazılıp sorgulanır.
Sorgulama sonucunda, varsayılan kimlik bilgilerini kullanan, bu nedenle yüksek risk taşıyan sistemlere ilişkin bilgiler listelenir.



SHODAN Filtreleme Parametreleri I

Shodan arama motorunda filtreleme parametreleri kullanılarak aramalar daha spesifik hâle getirilebilir:

1. city: Belirli bir şehre göre filtreleme yapar.
2. country: Belirli bir ülkeye göre filtreleme yapar.
3. os: İşletim sistemi bilgisine göre filtreleme yapar.
4. port: Açık olan port bilgisine göre filtreleme yapar.
5. product: Belirli bir ürüne göre filtreleme yapar.



SHODAN Filtreleme Parametreleri II

Diğer önemli Shodan filtreleme parametreleri:

1. hostname: Hostname veya domain bilgisine göre filtreleme yapar.
2. geo: Coğrafi lokasyon (enlem, boylam) bilgisine göre filtreleme yapar.
3. net: IP adresi veya subnet aralığına göre filtreleme yapar.
4. isp: İnternet servis sağlayıcıları bilgisine göre filtreleme yapar.
5. org: Kuruluş ismine göre filtreleme yapar.
6. server: Sunucu bilgisine göre filtreleme yapar.
7. title: Cihazların başlıklarında yazan bilgiye göre filtreleme yapar.

SHODAN Filtreleme Örnekleri

1. İstanbul'daki TELNET hizmeti açık cihazlar: country:TR city:Istanbul port:23
2. Vo***e ISS'li ve 21-25 arasındaki portları açık cihazlar: isp: 'Vo***e' port:21-25
3. Hindistan'daki 21, 22, 23, 24, 25 ve 80 numaralı portları açık cihazlar:
country:IN port:21-25 and 80
4. Bursa'daki Apache 2.2.3 versiyonu olan sistemler ('200 OK' ile): city:Bursa
'apache 2.2.3' '200 OK'

Google Dorking ve Google Hack Database

Kişi ve kurumların internet ortamında bıraktığı dijital ayak izleri, arama motorları tarafından indekslenir ve uzun süre erişilebilir kalır.

Google Dork, arama motorlarında araştırmaları daha etkili ve hedef odaklı hâle getirmek için kullanılan özel bir tekniktir.

Bu yöntemle bir web sitesindeki SQL açığına, belirli dosya uzantılarına sahip dosyalara ve birçok özel arama sonucuna hızlıca ulaşılabilir.



Google Dork Temel Anahtar Kelimeleri

Google arama motorundan bilgi toplamada kullanılabilecek bazı dorklar:

1. site: Belirtilen web site ile ilgili sonuçları listeler.
2. filetype: Belirtilen uzantıya sahip dosyaları listeler (örn: pdf, doc).
3. inurl: Belirtilen parametreyi içeren URL adreslerini listeler.
4. intitle: Belirtilen parametreyi içeren başlığa sahip olan sonuçları listeler.
5. intext: Belirtilen parametreyi içeren web sayfalarını listeler.
6. mail: Belirtilen domaine ait mail adreslerini listeler.

Google Dork Uygulama Örnekleri

1. Bir web sitesindeki belirli uzantılı dosyaları listeleme: `site:eba.gov.tr filetype:doc`
 2. Dizin listeleme (index of) başlığına sahip web sitelerini listeleme: `intitle:'index of'`
 3. Kritik parolaları içeren dosyaları listeleme: `intitle:'passwd'`
- Bu özel aramalar, yanlış yapılandırılmış sunuculardaki zafiyetleri tespit etmeye yardımcı olur.



Google Hack Database (GHDB)

Google Hack Database, potansiyel güvenlik zafiyetlerini veya kritik bilgileri ortaya çıkaran Google sorgularının listesini içeren bir indeksleme veri tabanıdır.

Erişim adresi: <https://www.exploit-db.com/google-hacking-database>

GHDB kullanılarak kullanıcı adı, parolalar, kritik bilgiler içeren hata mesajları ve güvenlik zafiyetleri bulunabilir.



OSINT Framework

OSINT Framework, kullanıcıları yüzlerce pasif bilgi toplama aracına kategorize edilmiş bir şekilde yönlendiren bir web sitesidir.

Bu site, siber güvenlik uzmanlarının hedeflerine uygun bilgi toplama araçlarını hızlıca bulmalarını sağlar.

Seçilen kategorideki araçlar ile pasif bilgi toplama faaliyeti gerçekleştirilebilir.



Aktif Bilgi Toplama Yöntemleri

Aktif bilgi toplama yöntemlerinde, bilgi alınmak istenen hedef ağ veya sistem ile doğrudan iletişime geçilir.

Bu nedenle, hedef sistemde log kaydı oluşur ve iz bırakılır.

Aktif bilgi toplama, saldırgan açısından en riskli bilgi toplama yöntemidir, bu yüzden dikkatli olunmalıdır.

Siber güvenlik uzmanları, savunma amaçlı olarak bu yöntemleri iyi bilmelidir.



Aktif Bilgi Toplamanın Amaçları

Aktif bilgi toplama yöntemleri, sızma testlerinde sistemlerin açıklarını tespit etmeye olanak sağlar.

Temel hedefler şunlardır:

1. Erişilebilen tüm sunucuların tespiti.
2. Sunucular üzerinde çalışan servis ve versiyonların tespiti.
3. Servis ve versiyonların potansiyel zafiyet analizinin yapılması.
4. Ağ hazırlanırken gerekli ayarların test edilmesi.

Nmap (Network Mapper) Yazılımı

Nmap, ağ haritasının ve topolojisinin çıkarılmasında kullanılan, açık kaynak kodlu ve en etkin ağ tarama yazılımıdır.

Gordon Lyon (Fyodor) tarafından geliştirilmiştir.

Nmap kullanım amaçları:

1. Ağ üzerindeki cihazların açık olan portlarını bulmak.
2. İşletim sistemlerini ve çalışan servis/versiyonlarını tespit etmek.
3. TCP/IP sistemlerini keşfetmek ve zafiyetlerini tespit etmek.

Nmap Çalışma Prensibi

Nmap, bir cihazı veya birden fazla cihazın bulunduğu ağı tarayabilir. Tarama işlemi, çeşitli ağ protokolleri aracılığıyla bilgi toplar. Ağdaki cihazlara ham paketler gönderilir ve bu paketlere verilen yanıtlar incelenerek keşif yapılır. Yanıtlar sayesinde portların açık, kapalı veya güvenlik duvarı tarafından filtreli olup olmadığı hakkında bilgi edinilebilir.

Nmap Basit Kullanımı

Nmap aracı, Kali Linux içinde kurulu olarak gelir. Hedef sisteme ait bir IP adresi veya web site adresi gerekir.

En basit kullanım şekli: `nmap <ip adresi>`

Varsayılan olarak, Nmap en çok kullanılan 1000 porta SYN taraması (gizli tarama) yapar.

SYN taraması, TCP protokolünün SYN bayrağını kullanarak açık hizmetlerin bulunmasını sağlar.



Nmap Tarama Sonuçlarının Yorumlanması

Nmap tarama sonucunda, hedef IP adresinin açık portları ve bu portlarda çalışan servisler listelenir. Sonuçlar ayrıca taramanın süresini, taranan port sayısını ve açık/filtreli portların miktarını gösterir (Örn: 16 port açık, 984 port filtreli).

Nmap Parametreleri: Dosya ve Hedef Belirleme

Ağ güvenliği testlerine başlamadan önce ağ üzerindeki açık sistemlerin tespiti için Nmap parametreleri kullanılır.

Dosya ve hedef belirleme parametreleri:

1. -iL <dosya adı>: IP adreslerinin belirtildiği dosyadan bilgileri alarak tarama yapar.
2. -iR <host sayısı>: Rastgele hedef seçerek belirtilen sayıda hostu tarar.
3. --exclude <host1,host2,...>: Taranması istenmeyen IP adresleri belirtilir.

Nmap Parametreleri: Host Keşfi ve Ping Teknikleri

Aktif hostların tespiti için kullanılan keşif parametreleri:

1. -sn: Port taramasını devre dışı bırakarak sadece ping atar ve aktif hostları tespit eder.
2. -Pn: Ping göndermeden tarar. Her IP adresini aktif kabul eder.
3. -PS: TCP SYN ping atarak keşif yapar.
4. -PA: TCP ACK ping atarak keşif yapar.
5. -PU: UDP ping atarak keşif yapar.
6. -PE: ICMP Echo Request ping atarak keşif yapar.

Nmap Parametreleri: DNS ve İzleme

DNS ve izleme ile ilgili parametreler:

1. -n: Asla DNS çözümülemesi yapılmaz (tarama hızını artırır).
2. -R: Her zaman DNS çözümülemesi yapılır.
3. --traceroute: Traceroute özelliğini aktif hâle getirir. Bu, hedefe giden ağ yolunu gösterir.

Nmap Port Tarama Tipleri I

Nmap, farklı protokol bayraklarını kullanarak çeşitli port tarama teknikleri sunar:

1. -sS: TCP SYN taraması yapar. Bu, genellikle 'Gizli Tarama' (Stealth Scan) olarak bilinir, çünkü tam TCP el sıkışmasını tamamlamaz ve loglanma ihtimali düşüktür.
2. -sT: TCP bağlantılı tarama yapar (Connect Scan). Tam üç yönlü el sıkışmasını tamamlar ve genellikle loglanır.
3. -sA: TCP ACK taraması yapar. Portun filtreli olup olmadığını anlamak için kullanılır (güvenlik duvarı testi).



Nmap Port Tarama Tipleri II

Diğer tarama tipleri:

1. -sU: UDP taraması yapar. UDP servislerinin tespiti için kullanılır, genellikle daha yavaştır.
2. -sN: TCP NULL taraması yapar. Bayrak seti olmayan paketler gönderir.
3. -sF: TCP FIN taraması yapar. Sadece FIN bayrağı ayarlanmış paketler gönderir.
4. -sO: IP protokolü taraması yapar. Hedefteki hangi IP protokollerinin desteklendiğini bulur.



Nmap Port Belirleme Parametreleri

Port belirlemeye yönelik önemli parametreler:

1. -p: Belirtilen portları tarar (Örn: -p 80,443).
2. -p-: Bir IP üzerinde bulunması muhtemel 0-65535 arasındaki tüm portları tarar.
3. -F: Daha hızlı tarama yapar. En çok kullanılan 100 port taranır.
4. --top-ports <sayı>: Belirtilen sayı kadar sık kullanılan portları tarar.

Nmap Servis ve İşletim Sistemi Tespiti

Nmap'in bilgi toplama derinliğini artıran parametreler:

1. -sV: Açık portta çalışan servisin versiyonunu tespit eder. (Genellikle -sC ile birlikte kullanılır).
2. -sC: -sV ile versiyon tespiti yapılırken Nmap Scripting Engine (NSE) scriptlerini kullanır.
3. -O: İşletim sistemi (OS) bilgisini tespit eder.
4. -A: Agresif tarama yapar (Bu, -O, -sV ve -sC gibi özellikleri birleştirir).

Nmap Detay ve Zamanlama Parametreleri

Tarama çıktısının detay seviyesini ve hızını ayarlayan parametreler:

1. -v, -vv: Ekranda gösterilecek detay seviyesini artırır.
2. --reason: Port durumunun nedenini gösterir (Örn: SYN/ACK alındığı için açık).
3. --open: Sadece açık portları gösterir.
4. -T: Zamanlama şablonu belirtir (0: Paranoyak, 5: İntikamcı). Tarama hızını ayarlar.

IP Tarama Teknikleri

IP tarama teknikleri; Host IP adresi, IP aralığı ve network (ağ) adreslerinin taranmasında kullanılır.

1. Host IP taraması: `nmap 192.168.56.101`
2. IP aralığı taraması: `nmap 192.168.56.101-102` (Belirli bir aralığı tarar)
3. Ağ taraması (CIDR): `nmap 192.168.56.0/24` (Tüm alt ağı tarar)



Nmap ile Domain Taraması

Nmap, IP adresleri yerine hedef domain adları üzerinden de tarama yapabilir.

Örnek: `nmap scanme.nmap.org -vv`

-vv parametresi, tarama sonuçlarının daha detaylı şekilde gösterilmesini sağlar.

Nmap bu domaini tararken, önce DNS çözümlemesi yapar ve ardından ilgili IP adresini hedefler.



Nmap: Dosyadan Hedef Alma

Çok sayıda hedefi aynı anda taramak için hedefler bir metin dosyasına kaydedilebilir (örneğin hedef.txt).

-iL parametresi ile dosyadaki IP adresleri Nmap'e okunur: `nmap -iL hedef.txt`

Bu yöntem, büyük sızma testlerinde hedef listelerinin yönetilmesini kolaylaştırır.



Port Tarama Teknikleri: Aktif Host Tespiti

Ağıdaki aktif hostları hızlıca tespit etmek için -sn parametresi kullanılır. Bu, port taramasını atlar ve sadece ping atarak hayatta olan sistemleri (Alive Hosts) belirler.

Kullanım: `nmap 192.168.56.0/24 -sn`

Bu sayede, tarama süresi önemli ölçüde kısaltılırken, ağıdaki hangi IP'lerin yanıt verdiği anlaşılır.



Port Tarama Teknikleri: Tekil ve Aralık Tarama

-p parametresi, belirli portları taramak için kullanılır.

1. Tekil port taraması: -p 80 (Sadece HTTP portunu tarar).

2. Belirli portları virgülle ayırarak tarama: -p 22,23 (SSH ve TELNET portlarını tarar).

3. Port aralığı taraması: -p 20-30 (Belirtilen aralıktaki tüm portları tarar).

Port Tarama Teknikleri: Tüm Portlar ve Açık Portlar

Tüm portları tarama: -p '*' parametresi ile 0'dan 65535'e kadar olan tüm portlar taranır.

Sadece açık portları tarama: --open parametresi ile sadece açık olan portlar listelenir.

Bu, filtreli veya kapalı portların sonuç ekranında yer almasını engelleyerek çıktıyı temizler.



Nmap TCP ve Protokol Tabanlı Tarama

Nmap, sadece TCP veya UDP portlarını hedef alabilir.

1. Tüm TCP portlarını tarama: -sT (veya -sS) parametresi ile tüm TCP portları taranır.
 2. Belirli bir TCP portunu tarama: -p T:443 parametresi ile sadece 443 numaralı TCP portu (HTTPS) taranır.
- Bu yöntem, spesifik bir protokolde çalışan bilinen hizmetler için hızlı testler yapmayı sağlar.



Portlarda Servis Tarama Teknikleri

Portlarda çalışan servislerin taranması, zafiyet tespiti önemli bir parçasıdır. Nmap Scripting Engine (NSE) araçları, --script parametresi kullanılarak zafiyet tespiti için kullanılabilir.

Örnekler:

1. FTP servisi kontrolü (Port 21): Güvenlik açıkları için FTP servisi taranır.
2. Microsoft-DS servisi kontrolü (Port 445): Windows işletim sistemlerinde kullanılan SMB servisinin zafiyetleri için taranır.

On-line Port Tarama Teknikleri

Port tarama işlemleri, web siteleri üzerinden de yapılabilir. Bu on-line araçlar, kullanıcıya Kali Linux gibi bir işletim sistemi kurma zorunluluğu olmadan hızlı bir port taraması imkanı sunar. Örnek on-line port tarama web sitesi: <https://viewdns.info/portscan>

Özet: Pasif ve Aktif Bilgi Toplama Karşılaştırması

Pasif Yöntemler:

- Doğrudan iletişim kurulmaz.
- Hedef sistemde log kaydı oluşmaz ve iz bırakılmaz.
- İnternet kaynakları kullanılır (Whois, Shodan.io, Archive.org).
- Yüzeysel bilgiler edinilir.

Aktif Yöntemler:

- Hedef sistemle doğrudan iletişime geçilir.
- Hedef sistemde log kaydı oluşur ve iz bırakılır (Yüksek riskli).
- Ağ haritalama ve port tarama araçları kullanılır (Nmap, hping3 gibi araçlar).
- Detaylı sistem ve zafiyet bilgileri elde edilir.

Ek Araçlar ve Uygulama Alanları

Öğrenilen temel keşif araçları ve amaçları:

1. SHODAN: İnternete bağlı cihazların tespiti ve detaylı port/servis bilgisi.
2. Whois: Alan adı sahibi iletişim ve teknik bilgilerini sorgulama.
3. theHarvester: E-posta adresleri ve alt alan adlarını tespit etme.
4. dnsenum/dnsrecon: DNS kayıtları, mail sunucuları ve bölge transferi denemeleri.
5. Nmap: Ağ haritalama, IP tarama ve servis versiyon tespiti.

Pasif Bilgi Toplama: Özet ve Değerlendirme I

ICANN (Internet Corporation for Assigned Names and Numbers), IP adreslerinin dağıtımında yetkili tek merkezdir.

RIPE NCC, Avrupa, Ortadoğu ve Orta Asya'daki IP adresi tahsislerinden sorumludur.

Whois sorgusu, yasal çerçevede alan adı/IP sahibi iletişim ve teknik bilgilerini listeler.

Bing arama motoru IP operatörü ('ip: ip_adresi'), bir sunucuda barınan web sitelerini listelemek için kullanılır.



Pasif Bilgi Toplama: Özet ve Değerlendirme II

Alan adı (Domain), IP adresinin akılda tutulması kolay kelimelerle ifade edilen hâlidir.

NS.TOOLS, alan adının aktifliğini ping ile kontrol eder ve DNS/IP bilgilerini toplar. Maltego, açık kaynak bilgileri toplayarak görselleştirir ve bağlantı analizi sağlar.

Archive.org, web sitelerinin 1996 yılından itibaren arşivlenmiş anlık görüntülerini sunar.



Ağ haritasını çıkarmak ve portları taramak amacıyla kullanılan temel aktif bilgi toplama yazılımı Nmap'tir.

Nmap'te kullanılan önemli parametreler:

- -sS: TCP SYN (Gizli) taraması için kullanılır.
- -Pn: Ping göndermeden tarama yapmak için kullanılır.
- -sV: Açık porttaki servisin versiyonunu tespit eder.
- -A: Agresif tarama (OS, Versiyon, Script).

Bilgi Toplama Yöntemleri

Süleyman **EZDEMİR**

suleyman.ezdemir@giresun.edu.tr

